

Secret 수명주기 검증

비밀정보 저장·주입·교체·폐기와 사고 대응 운영 기준

결과: Secret 수명주기를 실서버에서 검증했습니다

보호 저장소, 현재·직전 Grace Period, 폐기, 감사와 재부팅 복구를 실제 외부 HTTPS 경로에서 확인했습니다.

보호 저장소

root:ablecloud 0640
상위 0750
배포 경로 Symlink

Webhook 교체

Grace 202 / 202
Revoke 202 / 401
Gateway-only Restart

최종 결과

15 Controls PASS | Secret Leaks 0 | 6 Services Healthy | Reboot PASS

Secret의 권위와 실행 책임을 분리했습니다

운영자는 수명주기를 통제하고, 보호 저장소는 값을 보관하며, Activepieces는 주입된 값을 실행에만 사용합니다.

01

Protected Store

/etc 전용 저장소
root 소유
원자적 갱신
일반 백업 제외

02

Secret Control

Bootstrap
Rotate · Revoke
Rollback · Audit
Exposure Scan

03

AP Runtime

Compose env_file
Connection 암호화
Flow 실행
Secret 원장 아님

Secret 유형마다 교체와 사고 대응 규칙을 고정

모든 값을 같은 방식으로 바꾸지 않습니다. 암호화 Root, 세션, 저장소, Webhook과 외부 Token의 영향에 맞춰 절차를 분리했습니다.

분류	대표 값	교체 방식	유출 시
S1 Root	Encryption Key	복구 계획 선행	즉시 격리
S2 Session	JWT · API Key	작업 창 + 재시작	세션 무효화
S3 State	DB · Redis	양쪽 자격증명 조정	연결 폐기
S4 Webhook	HMAC Secret	Current + Previous	Grace 없이 폐기
S5 External	GitHub · AI Token	발급 → 전환 → 폐기	제공자 폐기
S6 Connection	Activepieces	재인가	Connection 무효화
감사	변경 Event	값 없는 JSONL	사고 기록
백업	Secret Recovery	일반 백업과 분리	격리·복원 훈련

실제 Secret 값은 Git·Issue·Flow·일반 백업·보고서·로그에 포함하지 않습니다.

생성부터 폐기까지 하나의 Runbook으로 반복

각 단계는 Secret 값을 출력하지 않으며 변경 범위, 검증 기준과 롤백 조건을 명시합니다.

A

분류·승인

Owner

유형 · 영향 · 작업 창

B

보호 저장

bootstrap

Store · Mode · Symlink

C

교체 준비

Grace

Current → Previous

D

발신 전환

Verify

Current 202 · Previous 202

E

직전 폐기

Revoke

Current 202 · Retired 401

F

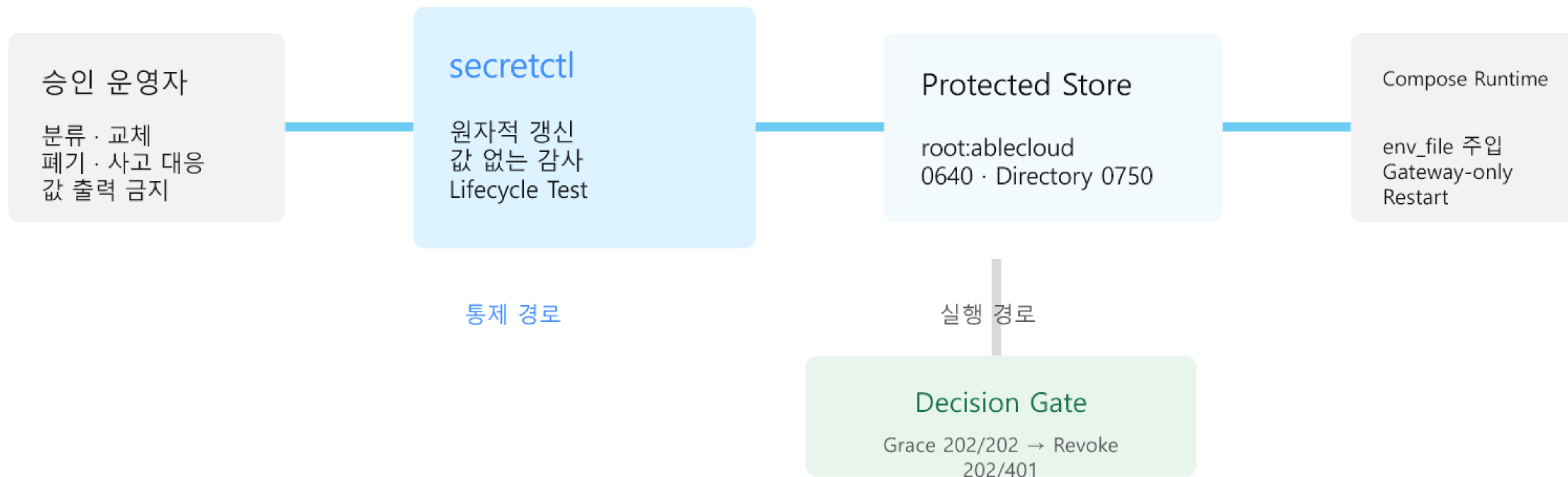
복구·감사

Reboot

Health · Scan · Audit

Secret 값은 보호 경로에서 런타임으로만 이동합니다

운영 명령과 감사 로그에는 값이 남지 않으며, Webhook 교체는 Event Gateway만 재생성해 상태 저장소 영향을 제한합니다.



저장·교체·노출·복구 15개 검증을 통과

V1-5

저장·기본 동작

Store Migration PASS
권한 PASS
6 Secrets Present
Unit 6/6
Current 202

저장·기본

V6-10

교체·영향

Previous 202
Current 202
Retired 401
Redis Unchanged
Asset Leaks 0

교체·영향

V11-15

회귀·복구

Log Leaks 0
HTTPS Regression PASS
Restart PASS
Reboot PASS
Backup Excludes .env

회귀·복구

결정.구현.운영 증거를 일관된 자산으로 관리

다음 운영자가 동일한 저장.교체.폐기.검증을 수행할 수 있도록 실행 코드와 문서, 구조화 증거를 함께 제공합니다.

실행 자산

secretctl · secret_env
secret_scan · verify-secrets
Gateway Dual Secret
Unit Tests 6/6

운영 문서

ADR-0002
Secret Lifecycle Runbook
환경 기준선 갱신
사고 대응 · 백업 경계

검증 증거

구조화 JSON
PDF 보고서 · PPTX
SHA-256 Manifest
시각·Overflow 검사

보안 기준 | Secret 미커밋 · 명령행 미전달 · 값 없는 감사 · 일반 백업 제외 · 노출 0건

다음 단계는 백업 복구 훈련과 첫 업무 Flow

Issue #15로 Secret 운영 통제를 확보했습니다. 다음은 데이터·Secret 복구 가능성을 증명한 뒤 GitHub PR Merge Flow를 실증하는 것입니다.



Issue #15 완료 기준 = 보호 저장소 + Grace/폐기 + 감사 + 노출 0 + 재시작·재부팅 복구

최종 결과

비밀정보 수명주기를
운영 가능한 기준으로 확정했습니다.

ISSUE #15

VALIDATED · 15 CONTROLS PASS · SECRET LEAKS 0 · REBOOT PASS